CO1 Assignment - 3

Name : E. Gowtham

Reg.No : 192311190

Course : Ethical Hacking

Code : ITA1412

1. Introduction

During a penetration test, discovering a SQL injection vulnerability in a production data base contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. (#) An ethical hacker must identify and report vulnerabilities without compromising customer privacy, data integrity, or System availability. The primary principles are authorization, confidentiality, integrity and non-maintance (avoiding harm). In a production database containing real customer financial data creates a serious ethical and security concern

Steps to proceed without causing Harm

Step-1: Stop risky exploitation

I would use a controlled, non-destructive test case to confirm the SQL injection

vulnerability. If possible attacks that could modify, delete or expose real financial records. I would not attempt to extract sensitive information merely to prove the vulnerability

Step 2: Verify the vulnerability safely

I would use a controlled, non-destructive test case to confirm the SQL injection vulnerability. If possible, I would test in a staging environment or use a specifically created test database containing dummy financial data

Step 3: Inform the client immediately

I would notify the authorized project manager or security contact about the vulnerability and the presence of real customer financial data. I would explain the potential risks and recommend pausing further exploitation until a safe testing method is approved

step 4: Protect sensitive information

I would not copy, download or disclose customer financial records. Any neccessary evidence would be limited to sanitized screenshots, error messages or logs that demonstrate the vulnerability without expos-ng personal information

Step 5: Document and report the findings

I would record the vulnerability, its potential impact, the safe testing method used and recommendations for reme-diation. The final report would be shared only with authorized recipents through a secure communication channel

step 6: Recommend remediation

I would recommend using parameterized queries or prepared statements, validating inputs appropriately, applying least-privilege database permissions, and conducting follows-up testing after the vulnerability is fixed

Precautions before the Engagement Began

i) Written authorization: obtain formal permission from the client to conduct the penetration test

ii) Clearly defined scope: specify the systems, databases, IP addresses and applications that may be tested

iii) Safe testing environment: prefer a staging environment with dummy data wherever possible

iv) Rules of engagement: permitted testing techniques, prohibited activities, testing hours and stop conditions

Ethical principles involved

Authorization: perform only activities explicitly approved by the client

Confidentiality: protect customer financial information from unauthorized access or disclosure

non-maleficence: Avoid unnecessary harm to customers and the organization

.Integrity: Prevent unauthorized changes to database records

.professional responsibility: Report vulnerabilities honsetly and recommend appropriate corrective measures

conclusion

An ethical hacker should not blindly follows a test plan when exploitation could expose real customer financial data. The correct approach is to stop risky testing, verify the vulnerability safely, inform the client, preserve confidentiality, and document the findings. Before the engagement, written authorization, clear scope, rules of engagement, data handling procedures and an emergency response plan should be established. This ensures that the penetration test improves security without causing harm.